

EtherApe

EtherApe is a network monitoring tool. It can be invoked by typing *etherape* in a terminal. It gives a graphical view of the communication (data exchange) between devices in the network. The graph includes the IP address or the domain name of the server or device being accessed. EtherApe also gives data about the protocols being used during the communication.

In Figure 3, the colour of the lines represents the protocol written on the left (red is for HTTP). The width of the lines represents the amount of traffic. You can see in this figure that there is heavy HTTP traffic.

Network monitoring gives attackers information on the Internet and intranet usage within a network. This makes it easy for the attacker to conclude patterns of usage, prior to planning an attack. For example, if the attackers plan to attack from another user's computer, they can monitor the traffic of all the users in the network and discover the time slot a given user will be absent, such as the time the victim goes to lunch every day. They can use that system to run malicious programs during that particular time slot.

ARPspooft

Let us first understand how the Address Resolution Protocol (ARP) works. Every packet going out of the device consists of seven layers (the OSI model). Each layer helps the packet in reaching the destination. Therefore, information in each layer is important. ARP is a Layer 2 protocol of the OSI model (Data Link layer). In the Data Link layer, the MAC address of the next physical device in the path is filled. Every device has a table known as ARP cache that maps the IP address to the corresponding MAC address. Devices use this table to fill the MAC address. When there is no entry corresponding to the IP address, then the ARP protocol is invoked. The ARP protocol broadcasts packets to find out the MAC address to the corresponding IP address. The device replies with its MAC address.

ARP spoofing

While sending out the ARP requests, if a malicious user replies with his MAC address, a legit IP address is mapped to a malicious MAC address. In the path to the destination, only the data in the Link layer and Physical layer are modified by the transit devices. Therefore, all the data goes through the malicious user, who can modify the data or just watch it.

In a network, all the packets going outside the local network go through the gateway. Performing ARP spoofing to intercept the packets from a victim to the gateway will help the attacker watch all the work done over the Internet by the victim.

There are many tools that can perform ARP poisoning. In this article, we will use the ARPspooft tool in Kali Linux.

When the attackers get the packets from the victim, they can forward them to the intended destination by using the following command:

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```

To perform ARP spoofing over an interface between a victim and the gateway, the following command is used:

```
arp spoof -i <interface-name> -t  
<victim IP> -r <gateway IP>
```

ARPspooft sends the victim machine the MAC address of the attacker as the gateway. Therefore, any traffic going outside the local network goes through the attacker.

Getting the user name and password

When the victim logs in to any HTTP or HTTPS site, the credentials can be obtained using ssl-strip along with ARPspooft.

Ssl-strip looks for HTTP traffic on the network, for HTTP links that redirect to HTTPS links and redirects those links to HTTP. For example, <https://domain.com/home.php> redirects

to <https://domain.com/login.php>. Ssl-strip changes this to <http://domain.com/login.php>.

As the attacker machine is between the victim and the gateway, all the traffic goes through it. Using ssl-strip, an attacker can get the credentials from those packets.

To set up ssl-strip, first forward all the packets coming on Port 80 (to the attacker machine from the victim machine) to Port 8080 for ssl-strip to analyse. Then set up ssl-strip on Port 8080.

For the purpose of this article, we have used <http://www.webscantest.com/login.php> as a test website.

As the victim clicks on the login button, the packets are forwarded to the attacker machine (because of ARPspooft). This traffic is forwarded to Port 8080 where ssl-strip analyses it. Ssl-strip creates a log file called *sslstrip.log* in the home folder, which contains the user credentials.

Driftnet

Driftnet is a network sniffing tool on Kali Linux that can be used to see the images viewed by the victim on the network. The images can be optionally saved using *-d*. By default, Driftnet sniffs over all the network interfaces.

```
root@kali:~# echo 1 > /proc/sys/net/ipv4/ip_forward  
root@kali:~# arpspoof -i eth0 -t 192.168.187.144 -r  
192.168.187.2
```

Figure 4: ARPspooft

```
root@kali:~# iptables -t nat -A PREROUTING -p tcp  
--destination-port 80 -j REDIRECT --to-port 8080  
root@kali:~# sslstrip -l 8080  
sslstrip 0.9 by Moxie Marlinspike running...
```

Figure 5: ssl-strip



Figure 6: Test website

Continued on page 48...